

Certification Practice Statement

Goya Ledger Public Key Infrastructure

Field	Value
Document OID	1.3.6.1.4.1.99999.2.2
Version	1.0.0
Status	Draft
Effective Date	2024-01-01
Publication URL	https://goya.cl/pki/cps
API Endpoint	GET /api/v1/cps/document
Governing CP OID	1.3.6.1.4.1.99999.2.1
Issuing Authority	Goya Ledger CA
Jurisdiction	Republic of Chile

Revision History

Version	Date	Author	Description
1.0.0	2024-01-01	Goya Ledger PKI Team	Initial draft aligned with RFC 3647

Table of Contents

- 1. [Introduction](#)
- 2. [Publication and Repository Responsibilities](#)
- 3. [Identification and Authentication](#)
- 4. [Certificate Life-Cycle Operational Requirements](#)
- 5. [Facility, Management, and Operational Controls](#)
- 6. [Technical Security Controls](#)
- 7. [Certificate, CRL, and OCSP Profiles](#)
- 8. [Compliance Audit and Other Assessments](#)
- 9. [Other Business and Legal Matters](#)

1. Introduction

1.1 Overview

This Certification Practice Statement (CPS) describes the practices and procedures employed by the Goya Ledger Certificate Authority (hereinafter “Goya CA”) in the issuance, management, revocation, and renewal of X.509 digital certificates within the Goya Ledger blockchain infrastructure.

The Goya CA operates as an internal, self-signed certificate authority serving a permissioned blockchain network built on Rust and Actix-Web 4. The PKI supports two legally distinct classes of electronic signature:

- **Firma Electronica Simple (FES):** Simple electronic signatures using Ed25519 (FIPS 186-5), providing authentication and integrity.
- **Firma Electronica Avanzada (FEA):** Advanced electronic signatures using ML-DSA-65 (FIPS 204), providing non-repudiation with biometric binding.

The system is designed to satisfy the requirements of Chilean Law 19.799 on Electronic Signatures, its implementing regulation DS 181/2002, the Chilean FEA Technical Standard (Decreto 24/2019), and the EU eIDAS Regulation (EU 910/2014) as applicable. The ETSI TS 102 042 policy framework and RFC 3647 document structure are followed throughout.

The PKI implementation is contained primarily in the following codebase modules:

Module	Path	Responsibility
CA core	src/pki.rs	Certificate authority, issuance, QCStatements
Chain validation	src/pki_chain.rs	X.509 chain validation
Policy framework	src/pki_policy.rs	CP/CPS metadata, OIDs, profiles
Key ceremony	src/pki_ceremony.rs	Root key ceremony protocol
Lifecycle manager	src/pki_lifecycle.rs	Revocation, suspension, CRL publication
CRL generator	src/msp/crl_rfc5280.rs	RFC 5280 CRL encoding
OCSP responder	src/msp/ocsp.rs, src/msp/ocsp_der.rs	RFC 6960 OCSP responses
TSA	src/tsa/mod.rs, src/tsa/rfc3161_der.rs	RFC 3161 timestamping
Registration Authority	src/identity/ra.rs	Identity proofing workflow
DID	src/identity/did.rs	Decentralized identifier management
Signing providers	src/identity/signing.rs	Ed25519, ML-DSA-65, RSA providers
HSM integration	src/identity/hsm.rs	

Module	Path	Responsibility
		PKCS#11 hardware security module
Audit	src/audit.rs	Hash-chained audit logging
Crypto module	crates/ pqc_crypto_module/	FIPS-oriented cryptographic primitives
Signature framework	src/signature/	FES/FEA, CAdES, PAdES, XAdES
API handlers	src/api/handlers/	HTTP endpoints for PKI services

1.2 Document Name and Identification

Attribute	Value
Document title	Goya Ledger Certification Practice Statement
Document OID	1.3.6.1.4.1.99999.2.2
OID arc root	1.3.6.1.4.1.99999 (Goya Private Enterprise Number, placeholder)
Related CP OID	1.3.6.1.4.1.99999.2.1
TSA Policy OID	1.3.6.1.4.1.99999.1.1
Signature Policy OID	1.3.6.1.4.1.99999.3.1

The OID namespace is defined in `src/pki_policy.rs` as constants `GOYA_OID_ROOT`, `CP_OID`, `CPS_OID`, `TSA_POLICY_OID`, and `SIGNATURE_POLICY_OID`. The placeholder PEN 99999 shall be replaced with the IANA-assigned Private Enterprise Number upon formal registration.

1.3 PKI Participants

1.3.1 Certificate Authorities

The Goya CA operates a two-tier hierarchy implemented in `src/pki.rs`:

- **Root CA:** Self-signed ECDSA P-256 certificate generated via `rcgen`. Common Name: Rust-BC Internal CA. Validity: 10 years (2024-01-01 to 2034-01-01). Basic Constraints: `CA:TRUE` (unconstrained). The Root CA private key is maintained offline except during intermediate CA signing ceremonies.
- **Intermediate CA:** Signed by the Root CA. Common Name: Goya Ledger Intermediate CA. Validity: 5 years from generation. Basic Constraints: `CA:TRUE`, `pathLenConstraint:0`. The Intermediate CA is the operational issuing CA for all end-entity certificates.

The hierarchy is represented by the `CaHierarchy` struct containing both the root and intermediate `CertifiedKey` instances.

1.3.2 Registration Authorities

The Registration Authority (RA) is implemented in `src/identity/ra.rs`. The RA is responsible for verifying subscriber identity before certificate issuance, in compliance with Ley 19.799 Article 15.

RA officers are identified by their Decentralized Identifier (DID) and must be authorized within the system's access control framework. The RA maintains an RaStore for identity proofing records with the following workflow states defined in the `ProofingStatus` enum:

- **Pending** – awaiting officer review
- **Verified** – identity confirmed, certificate may be issued
- **Rejected** – identity proofing failed

1.3.3 Subscribers

Subscribers are natural persons, legal persons, or network nodes that hold certificates issued by the Goya CA. Three certificate profiles are defined (see Section 7.1):

- **FES Subscriber:** Natural or legal persons using simple electronic signatures.
- **FEA Subscriber:** Natural or legal persons requiring advanced electronic signatures with biometric binding.
- **TSA Signing:** The Time-Stamping Authority signing certificate.

Additionally, network node certificates are issued for P2P TLS communication.

1.3.4 Relying Parties

Relying parties are any entities that verify signatures, validate certificates, or check revocation status using the Goya PKI. Relying parties access certificate status via the CRL distribution endpoint (`GET /api/v1/crl`) and the OCSP responder (`POST /api/v1/ocsp/query`).

1.3.5 Other Participants

- **Auditors:** Authorized personnel who review the hash-chained audit log (see `src/audit.rs`).
- **Witnesses and Notaries:** Required participants in key ceremony procedures (see `src/pki_ceremony.rs`).

1.4 Certificate Usage

1.4.1 Appropriate Certificate Uses

Certificate Profile	Permitted Uses
FES Subscriber	Digital signatures under Ley 19.799 FES; authentication; email signing
FEA Subscriber	Advanced electronic signatures under Ley 19.799 FEA; non-repudiation;

Certificate Profile	Permitted Uses
TSA Signing	eIDAS Advanced signatures; document signing with legal force
Node TLS	RFC 3161 timestamp token signing
	Mutual TLS for P2P blockchain communication; API TLS termination

1.4.2 Prohibited Certificate Uses

Certificates issued under this CPS shall not be used for:

- Purposes inconsistent with the key usage extensions in the certificate.
- Signatures on content that violates applicable law.
- FES certificates for purposes requiring non-repudiation or advanced/qualified signature status.
- Node TLS certificates for end-user document signing.

1.5 Policy Administration

1.5.1 Organization Administering the Document

Goya Ledger PKI Team, operating under the governance framework defined in `src/governance/`.

1.5.2 Contact Information

Policy inquiries: `pki@goya.cl` Publication URL: `https://goya.cl/pki/cps`

1.5.3 CPS Approval Procedures

Amendments to this CPS require review by the PKI Policy Board, a security impact assessment, and formal approval recorded in the audit log under the `SecurityOfficerConfigChange` event type (defined in `src/audit.rs`).

Material changes that affect relying party trust (algorithm changes, validity period modifications, RA procedure changes) require a new CPS version with a 30-day notice period before the effective date.

1.5.4 CPS Suitability Determination

The governing Certificate Policy (CP, OID `1.3.6.1.4.1.99999.2.1`) defines the high-level requirements. This CPS details how those requirements are operationally fulfilled. Relying parties should consult both documents.

1.6 Definitions and Acronyms

Term	Definition
CA	Certificate Authority

Term	Definition
CP	Certificate Policy
CPS	Certification Practice Statement
CRL	Certificate Revocation List
CSPRNG	Cryptographically Secure Pseudo-Random Number Generator
DID	Decentralized Identifier
FEA	Firma Electronica Avanzada (Advanced Electronic Signature)
FES	Firma Electronica Simple (Simple Electronic Signature)
FIPS	Federal Information Processing Standard
HSM	Hardware Security Module
ML-DSA	Module-Lattice Digital Signature Algorithm (FIPS 204)
OCSP	Online Certificate Status Protocol
OID	Object Identifier
PEN	Private Enterprise Number
PQC	Post-Quantum Cryptography
RA	Registration Authority
RUT	Rol Unico Tributario (Chilean national tax identifier)
TSA	Time-Stamping Authority

2. Publication and Repository Responsibilities

2.1 Repositories

The Goya CA maintains the following information repositories, accessible via the node's HTTP API (default port 8080, configurable via `API_PORT`):

Resource	Endpoint	Format	Module
Certificate Policy	GET /api/v1/policy/cp	JSON	src/api/handlers/policy.rs
CPS	GET /api/v1/policy/cps	JSON	src/api/handlers/policy.rs
CP document (RFC 3647)	GET /api/v1/cp/document	Markdown	src/api/handlers/policy.rs
CPS document (RFC 3647)	GET /api/v1/cps/document	Markdown	src/api/handlers/policy.rs
OID registry	GET /api/v1/policy/oids	JSON	src/api/handlers/policy.rs

Resource	Endpoint	Format	Module
CRL (DER)	GET /api/v1/crl	application/pkix-crl	src/api/handlers/crl.rs
CRL (PEM)	GET /api/v1/crl/pem	application/x-pem-file	src/api/handlers/crl.rs
OCSP responder	POST /api/v1/ocsp/query	JSON	src/api/handlers/ocsp.rs
OCSP responder (DER)	POST /api/v1/ocsp/query/der	application/ocsp-response	src/api/handlers/ocsp.rs
OCSP status lookup	GET /api/v1/ocsp/status/{msp_id}/{serial}	JSON	src/api/handlers/ocsp.rs
TSA	POST /api/v1/tsa/timestamp	JSON	src/api/handlers/tsa.rs
TSA (DER)	POST /api/v1/tsa/timestamp/der	application/timestamp-reply	src/api/handlers/tsa.rs
TSA policy	GET /api/v1/tsa/policy	JSON	src/api/handlers/tsa.rs

2.2 Publication of Certification Information

The CA publishes:

1. **This CPS** at the URL specified in Section 1.2, and programmatically via the /api/v1/cps/document endpoint.
2. **The Certificate Policy** at <https://goya.cl/pki/cp> and via /api/v1/cp/document.
3. **Certificate Revocation Lists** in both DER and PEM formats, updated upon each revocation event and at minimum every 7 days (the `crl_validity_days` parameter in `src/pki_lifecycle.rs`).
4. **OCSP responses** in real time via the OCSP responder endpoints.
5. **Root CA and Intermediate CA certificates** available for download to enable chain validation.

2.3 Time or Frequency of Publication

Artifact	Publication Frequency
CPS	Upon each version change
CRL	Within 1 hour of any revocation; at minimum every 7 days

Artifact	Publication Frequency
OCSP responses	Real-time, with 1-hour validity window (validity_secs = 3600 in src/msp/ocsp.rs)
CA certificates	Upon CA key ceremony completion

The 1-hour CRL publication deadline following revocation is mandated by DS 181/2002 Article 17 and enforced by the LifecycleManager in src/pki_lifecycle.rs.

2.4 Access Controls on Repositories

- Policy documents (CP, CPS, OID registry) are publicly readable without authentication.
- CRL and OCSP endpoints are publicly accessible to enable universal revocation checking.
- Administrative endpoints (certificate issuance, revocation, RA operations) are protected by the access control layer (enforce_acl in src/api/) with mode configurable via the ACL_MODE environment variable.
- Production deployments (RUST_BC_ENV=production) require TLS (TLS_CERT_PATH, TLS_KEY_PATH) and warn when ACL_MODE=permissive.

3. Identification and Authentication

3.1 Naming

3.1.1 Types of Names

Certificates issued by the Goya CA contain the following name forms:

- **Subject Distinguished Name (DN):** Contains at minimum a Common Name (CN). For node certificates, the CN is set to the node identifier. For subscriber certificates, the CN is derived from the subscriber's legal name as verified by the RA.
- **Subject Alternative Name (SAN):** For node TLS certificates, a DNS SAN is included matching the node identifier. Implemented in sign_node_cert() within src/pki.rs.
- **Decentralized Identifier (DID):** Each subscriber is assigned a DID in the format did:goya:{pubkey_hex[..16]}, derived deterministically from the public key via did_from_pubkey_hex() in src/identity/did.rs.

3.1.2 Need for Names to Be Meaningful

Subject names in certificates must meaningfully identify the subscriber. For natural persons, this is the legal name as recorded on the government-issued identification document. For legal persons, this is the registered legal entity name.

3.1.3 Anonymity or Pseudonymity of Subscribers

Anonymity is not permitted for FEA certificates. FES certificates may use pseudonymous identifiers subject to the RA recording the true identity of the subscriber in the identity proofing record.

DIDs are pseudonymous by construction (derived from the first 8 bytes of the public key hash), but the RA maintains the binding between DID and verified real-world identity.

3.1.4 Rules for Interpreting Various Name Forms

Distinguished Name components follow ITU-T X.520. The DID format follows the W3C DID Core specification with the goya method identifier.

3.1.5 Uniqueness of Names

DID uniqueness is guaranteed by the deterministic derivation from the subscriber's public key. The `did_matches_pubkey()` function in `src/identity/did.rs` provides verification that a DID corresponds to a given public key.

Certificate serial numbers are unique within the scope of the issuing CA.

3.1.6 Recognition, Authentication, and Role of Trademarks

The Goya CA does not issue certificates containing trademarked names without proof of the applicant's right to use such marks.

3.2 Initial Identity Validation

3.2.1 Method to Prove Possession of Private Key

The subscriber demonstrates possession of the private key by submitting a signed request to the RA. The CA verifies the signature using the corresponding public key before certificate issuance. Key pairs are generated client-side using OS-backed CSPRNG (`OsRng`), implemented in `src/identity/signing.rs`.

3.2.2 Authentication of Organization Identity

For legal person (electronic seal) certificates:

1. The RA verifies the organization's legal existence through official Chilean registry records.
2. The Chilean RUT (Rol Unico Tributario) is validated using the modulo 11 check-digit algorithm implemented in `src/identity/ra.rs`.
3. The authorized representative's identity is verified per the natural person procedures below.
4. Authorization to act on behalf of the organization is confirmed through notarized power of attorney or equivalent legal instrument.

3.2.3 Authentication of Individual Identity

The RA supports three identity proofing methods, defined in the `ProofingMethod` enum in `src/identity/ra.rs`:

Method	Assurance Level	Procedure
InPerson	High	Face-to-face presentation of government-issued photo ID (cedula de identidad or passport). RA officer verifies document authenticity, compares photograph, and records document details.
VideoConference	High	Real-time video session where the subscriber presents their government-issued ID. RA officer captures session evidence and performs liveness verification.
RemoteAutomated	Medium	Automated verification via a trusted third-party identity service. Suitable for FES certificates only.

For FEA certificates (advanced electronic signatures), only InPerson or VideoConference methods are accepted, providing High assurance as required by Decreto 24/2019.

All proofing records include: subscriber DID, RUT, legal name, proofing method, status, submission timestamp, and the approving RA officer's DID.

3.2.4 Non-Verified Subscriber Information

The following information in certificate requests is not independently verified by the RA:

- Email addresses (unless required by the certificate profile).
- Organizational unit names within a verified organization.

Non-verified information is not included in the certificate Subject DN but may be recorded in RA metadata.

3.2.5 Validation of Authority

For certificates issued to representatives of legal persons, the RA verifies that the requesting individual has authority to act on behalf of the organization through legally recognized instruments (powers of attorney, corporate resolutions).

3.2.6 Criteria for Interoperation

The Goya CA supports RSA-2048 (via `RsaSigningProvider` in `src/identity/signing.rs`) for interoperability with external systems that do not yet support Ed25519 or ML-DSA-65. Cross-certification with external CAs is governed by the procedures in `docs/compliance/CROSS-CERTIFICATION.md`.

3.3 Identification and Authentication for Re-Key Requests

3.3.1 Routine Re-Key

For routine re-key (certificate renewal before expiration), the subscriber authenticates using their current valid certificate. The `renew_node_cert()` function in `src/pki.rs` generates a fresh key pair and new certificate; the caller must revoke the old certificate. The `LifecycleManager` tracks `CertificateRenewed` events.

3.3.2 Re-Key After Revocation

After revocation, the subscriber must complete the full initial identity validation process described in Section 3.2. No abbreviated procedure is available.

3.4 Identification and Authentication for Revocation Requests

Revocation requests are authenticated by one of the following methods:

1. The subscriber signs the revocation request with the private key corresponding to the certificate to be revoked.
2. An authorized RA officer initiates revocation, identified by their DID.
3. A Security Officer initiates emergency revocation, recorded under the `SecurityOfficerConfigChange` audit event type.

The `revoke_and_publish_crl()` method in `src/pki_lifecycle.rs` processes revocations and immediately triggers CRL republication.

4. Certificate Life-Cycle Operational Requirements

4.1 Certificate Application

4.1.1 Who Can Submit a Certificate Application

- Natural persons of legal age with a valid Chilean cedula de identidad or passport.
- Legal persons through an authorized representative.
- Network nodes through automated provisioning (`provision_node_cert_if_absent()` in `src/pki.rs`).

4.1.2 Enrollment Process and Responsibilities

The enrollment process proceeds as follows:

1. **Key generation:** The subscriber generates a key pair using the appropriate `SigningProvider` (Ed25519 for FES, ML-DSA-65 for FEA). Implemented in `src/identity/signing.rs`.
2. **DID creation:** A DID is derived from the public key via `did_from_pubkey_hex()` in `src/identity/did.rs`.
3. **Identity proofing submission:** The subscriber submits an identity proofing request to `POST /api/v1/identity/proof`, handled by `src/api/handlers/ra.rs`.
4. **RA verification:** An RA officer reviews the proofing request, performs identity checks per Section 3.2, and approves or rejects.
5. **Certificate issuance:** Upon RA approval, `approve_and_issue_cert()` in `src/identity/ra.rs` combines the approval with CA certificate issuance.

4.2 Certificate Application Processing

4.2.1 Performing Identification and Authentication Functions

The RA performs all identification and authentication functions described in Section 3. The RA officer must be an authorized individual identified by a valid DID within the access control system.

4.2.2 Approval or Rejection of Certificate Applications

Approval is granted when:

- The subscriber's identity has been verified to the required assurance level.
- For Chilean subscribers, the RUT has been validated via the modulo 11 algorithm.
- The subscriber has demonstrated possession of the private key.
- The requested certificate profile matches the verified assurance level.

Rejection occurs when any of the above conditions are not met. The reason for rejection is recorded in the RA store and the `IdentityProofingRejected` audit event is logged.

API endpoints for approval and rejection:

- `POST /api/v1/identity/proof/{did}/approve`
- `POST /api/v1/identity/proof/{did}/reject`

4.2.3 Time to Process Certificate Applications

Certificate applications are processed within the following targets:

- Automated node certificate provisioning: immediate (sub-second).
- FES applications with remote automated proofing: within 1 business day.
- FEA applications requiring in-person or video proofing: within 5 business days.

4.3 Certificate Issuance

4.3.1 CA Actions During Certificate Issuance

Upon RA approval, the CA:

1. Validates the certificate request against the applicable certificate profile.
2. Generates the X.509 certificate signed by the Intermediate CA using ECDSA P-256 (via rcgen).
3. Embeds the `certificatePolicies` extension (OID 2.5.29.32) with the CP OID and CPS URI, implemented in `certificate_policies_extension()` in `src/pki.rs`.
4. Embeds `QCStatements` (OID 1.3.6.1.5.5.7.1.3) per EN 319 412-5, selecting the appropriate `QcType` (esign, esel, or web) based on the certificate profile. Implemented in `qc_statements_extension()` and `build_qc_statements_der()` in `src/pki.rs`.
5. Records a `CertificateIssued` event in the audit log.
6. Returns the `IssuedNodeCert` containing DER, PEM certificate, and PEM private key (for node certificates).

4.3.2 Notification to Subscriber by the CA of Issuance

The subscriber is notified of certificate issuance through the API response to the approval request. The certificate is available immediately upon issuance.

4.4 Certificate Acceptance

4.4.1 Conduct Constituting Certificate Acceptance

Use of the certificate for signing constitutes acceptance. For FEA certificates, acceptance is further evidenced by the subscriber's acknowledgment of obligations during the identity proofing process.

4.4.2 Publication of the Certificate by the CA

Issued certificates are stored in the CA's certificate store. The CA does not operate a public certificate directory; certificates are distributed by the subscriber to relying parties.

4.4.3 Notification of Certificate Issuance by the CA to Other Entities

The audit log records all issuance events. The RA is notified through the API workflow. No other notification is sent.

4.5 Key Pair and Certificate Usage

4.5.1 Subscriber Private Key and Certificate Usage

Subscribers shall:

- Protect private keys from unauthorized access. Software keys are protected with `ZeroizeOnDrop` and `mlock` (implemented in `src/identity/signing.rs`). HSM-stored keys are protected by the HSM's access control.
- Use certificates only for the purposes indicated by the key usage extensions.
- Report suspected key compromise to the CA within 24 hours.
- Provide accurate information during the enrollment process.
- Cease use of a certificate upon expiration or revocation.

4.5.2 Relying Party Public Key and Certificate Usage

Relying parties shall:

- Verify the certificate chain to a trusted root using `validate_chain()` in `src/pki_chain.rs`.
- Check certificate validity (not-before, not-after) using `validate_cert_der()`.
- Check revocation status via CRL or OCSP before relying on a certificate.
- Verify that the certificate's key usage extensions permit the intended use.

4.6 Certificate Renewal

Certificate renewal (issuance of a new certificate with a new validity period but the same key pair) is not supported. All re-key operations generate a fresh key pair per Section 3.3.

4.7 Certificate Re-Key

4.7.1 Circumstances for Certificate Re-Key

Re-key is performed when:

- The current certificate is approaching expiration (detected by `check_expiring()` in `src/pki_lifecycle.rs`, using the configurable `expiry_warning_days` threshold).
- The subscriber's private key has been compromised.
- The subscriber requires a change in certificate attributes.

4.7.2 Who May Request Re-Key

The subscriber or an authorized RA officer may request re-key. For node certificates, automated re-key is triggered by the expiry warning system.

4.7.3 Processing Certificate Re-Key Requests

Re-key follows the procedure in `renew_node_cert()` in `src/pki.rs`:

1. A new ECDSA P-256 key pair is generated.
2. A new certificate is issued with a fresh validity period.
3. The old certificate must be revoked by the caller.
4. A `CertificateRenewed` lifecycle event is recorded.

4.7.4 Notification of New Certificate Issuance to Subscriber

The new certificate is returned in the API response. The `CertificateExpiring` lifecycle event type provides advance warning.

4.7.5 Conduct Constituting Acceptance of a Re-Keyed Certificate

Use of the re-keyed certificate constitutes acceptance. The subscriber must confirm revocation of the previous certificate.

4.7.6 Publication of the Re-Keyed Certificate by the CA

The re-keyed certificate is made available via the same mechanisms as initial issuance.

4.7.7 Notification of Certificate Issuance by the CA to Other Entities

Notification follows the same procedure as initial issuance (Section 4.3.2).

4.8 Certificate Modification

Certificate modification (changing certificate content without re-key) is not supported. A new certificate must be issued through the re-key process.

4.9 Certificate Revocation and Suspension

4.9.1 Circumstances for Revocation

A certificate shall be revoked when:

- The subscriber's private key is compromised or suspected of compromise.
- The information in the certificate is no longer accurate.
- The subscriber has violated the terms of the CP or this CPS.
- The CA determines that the certificate was not issued in accordance with applicable procedures.
- The subscriber requests revocation.
- The RA determines that identity proofing was insufficient or fraudulent.
- Required by law or court order.

4.9.2 Who Can Request Revocation

- The subscriber (authenticated per Section 3.4).
- An RA officer.
- A Security Officer.
- The CA, acting on its own authority in cases of policy violation or compromise.

4.9.3 Procedure for Revocation Request

1. The revocation request is submitted and authenticated per Section 3.4.
2. The LifecycleManager processes the request via `revoke_and_publish_crl()` in `src/pki_lifecycle.rs`.
3. The certificate serial number is added to the revocation list.
4. A new CRL is generated and published immediately.
5. A `CertificateRevoked` event is logged in the audit trail.
6. OCSP responses for the certificate transition to Revoked status.

4.9.4 Revocation Request Grace Period

There is no grace period. Revocation is effective immediately upon processing.

4.9.5 Time Within Which CA Must Process the Revocation Request

Revocation requests are processed immediately upon receipt and authentication. The updated CRL is published within 1 hour per DS 181/2002 Article 17.

4.9.6 Revocation Checking Requirement for Relying Parties

Relying parties must check the revocation status of certificates before reliance, using either CRL or OCSP.

4.9.7 CRL Issuance Frequency

- **Routine CRL publication:** Every 7 days (configurable via `crl_validity_days` in `src/pki_lifecycle.rs`).
- **Emergency CRL publication:** Within 1 hour of any revocation event.

4.9.8 Maximum Latency for CRLs

CRLs are published within 1 hour of the triggering event (revocation or scheduled update).

4.9.9 On-Line Revocation/Status Checking Availability

OCSP is available 24x7 via:

- `POST /api/v1/ocsp/query` (JSON format)
- `POST /api/v1/ocsp/query/der` (DER format, `application/ocsp-response`)
- `GET /api/v1/ocsp/status/{msp_id}/{serial}` (direct lookup)

OCSP responses have a validity period of 3,600 seconds (1 hour), configurable via `with_validity_secs()` on the OCSP responder in `src/msp/ocsp.rs`.

4.9.10 On-Line Revocation Checking Requirements

The OCSP responder supports nonce-based replay protection per RFC 6960. Signed OCSP responses are generated using the configured `SigningProvider` (Ed25519, ML-DSA-65, or RSA). Response verification is available via `verify_ocsp_response()`.

DER-encoded responses follow RFC 6960 Section 4.2.1, implemented in `src/msp/ocsp_der.rs`, with the following algorithm OIDs:

Algorithm	OID
Ed25519	1.3.101.112
ML-DSA-65	2.16.840.1.101.3.4.3.17
RSA-SHA256	1.2.840.113549.1.1.11

The `ResponderID` is computed as `byKey` using SHA-256 of the responder's public key (first 20 bytes).

4.9.11 Other Forms of Revocation Advertisements Available

No other forms are currently provided.

4.9.12 Special Requirements Related to Key Compromise

Upon confirmed key compromise:

1. Immediate revocation per Section 4.9.3.
2. The `KeyDeactivated` and `KeyDestroyed` audit events are logged.
3. All certificates issued using the compromised key are identified and revoked.
4. If the compromise affects a CA key, the incident response plan in `docs/compliance/INCIDENT-RESPONSE-PLAN.md` is activated.

4.9.13 Circumstances for Suspension

Certificate suspension (temporary hold) is supported via `suspend_and_publish_crl()` in `src/pki_lifecycle.rs`. Suspension places the certificate on the CRL with reason code `certificateHold`.

Circumstances for suspension:

- Suspected but unconfirmed key compromise pending investigation.
- Subscriber request for temporary hold.
- RA-initiated hold pending re-verification.

4.9.14 Who Can Request Suspension

The same parties authorized to request revocation (Section 4.9.2).

4.9.15 Procedure for Suspension Request

1. The request is submitted and authenticated.
2. The LifecycleManager processes the request via `suspend_and_publish_crl()`.
3. The certificate is placed on the CRL with `certificateHold` reason.
4. A `CertificateSuspended` lifecycle event is recorded.

4.9.16 Limits on Suspension Period

Suspended certificates must be either reinstated or revoked within 30 days. Reinstatement is performed via `reinstate_and_publish_crl()` in `src/pki_lifecycle.rs`, which removes the certificate from the CRL and records a `CertificateReinstated` event.

4.10 Certificate Status Services

4.10.1 Operational Characteristics

The OCSP responder provides real-time certificate status with three possible states defined in the `CertStatus` enum in `src/msp/ocsp.rs`:

- Good – the certificate is valid and not revoked.
- Revoked – the certificate has been revoked.
- Unknown – the certificate is not recognized by this CA.

4.10.2 Service Availability

The OCSP and CRL services are available whenever the node is operational. For production deployments, high availability is achieved through the multi-node architecture described in `docs/api/DEPLOYMENT.md`.

4.10.3 Optional Features

The OCSP responder supports nonce extensions for replay protection. JSON export with verification flags is available for integration convenience.

4.11 End of Subscription

Upon end of subscription:

1. All active certificates for the subscriber are revoked.
2. The subscriber's DID status is set to `Revoked` in the identity store.
3. Identity proofing records are retained for 7 years per the document retention policy.

4.12 Key Escrow and Recovery

4.12.1 Key Escrow and Recovery Policy and Practices

CA private keys are subject to backup and recovery procedures. The `KeyBackedUp` and `KeyRestored` audit event types track these operations.

For HSM-deployed keys (feature-gated under `hsm` in `src/identity/hsm.rs`):

- HSM-to-HSM key wrapping using `CKM_AES_KEY_WRAP`.
- Shamir M-of-N secret sharing for disaster recovery.

Subscriber private keys are never escrowed. Key generation occurs client-side, and the CA never possesses subscriber private keys (except for node certificates issued via `sign_node_cert()`, where the key pair is generated and returned to the requesting node).

4.12.2 Session Key Encapsulation and Recovery Policy and Practices

Not applicable. The Goya PKI does not issue key encapsulation certificates.

5. Facility, Management, and Operational Controls

5.1 Physical Controls

5.1.1 Site Location and Construction

The physical security requirements for the CA infrastructure are documented in `docs/compliance/PHYSICAL-SECURITY.md`. Production CA operations shall be conducted in a physically secured facility with controlled access.

5.1.2 Physical Access

Access to CA systems requires multi-factor authentication and is logged. The Root CA key material is stored offline in a physically secured location accessible only during key ceremony procedures.

5.1.3 Power and Air Conditioning

Production facilities maintain uninterruptible power supply (UPS) and environmental controls appropriate to the equipment.

5.1.4 Water Exposures

Equipment is located above flood levels and protected from water damage.

5.1.5 Fire Prevention and Protection

Fire detection and suppression systems appropriate for electronic equipment are maintained.

5.1.6 Media Storage

Sensitive media (HSM backup tokens, key ceremony records) are stored in fire-rated safes with access controls.

5.1.7 Waste Disposal

Sensitive materials are destroyed via shredding (paper) or secure erasure (electronic media) per the security policy.

5.1.8 Off-Site Backup

Backup procedures are documented in docs/compliance/BUSINESS-CONTINUITY-DR.md. CA key material backups are stored at geographically separated locations.

5.2 Procedural Controls

5.2.1 Trusted Roles

The following trusted roles are defined in the CeremonyRole enum in src/pki_ceremony.rs:

Role	Responsibility
Administrator	System administration and configuration
Custodian	Key share custody (M-of-N)
Witness	Observes and attests to ceremony procedures
Auditor	Reviews audit logs and compliance evidence
Notary	Provides legal attestation for key ceremonies

Security Officer operations are tracked via the SecurityOfficerLogin, SecurityOfficerConfigChange, and SecurityOfficerRoleAssigned audit event types in src/audit.rs.

5.2.2 Number of Persons Required per Task

Critical operations require multi-person authorization:

- **Root CA key ceremony:** Minimum 2 witnesses, 3 custodians (for 2-of-3 Shamir threshold), and 1 notary (configurable via CeremonyConfig in src/pki_ceremony.rs).
- **CRL signing:** Single authorized operator.
- **RA approval:** Single authorized RA officer.

5.2.3 Identification and Authentication for Each Role

All trusted roles are authenticated via their DID and associated credentials within the access control framework.

5.2.4 Roles Requiring Separation of Duties

- The RA officer who verifies identity shall not also perform the CA certificate issuance operation.
- Key custodians shall not also hold the Administrator role.
- Auditors shall be independent of CA operations.

5.3 Personnel Controls

5.3.1 Qualifications, Experience, and Clearance Requirements

Personnel in trusted roles must possess appropriate qualifications in information security and PKI operations. Background checks are required before assuming trusted roles.

5.3.2 Background Check Procedures

Background checks include identity verification, criminal record check, and professional reference verification.

5.3.3 Training Requirements

All trusted personnel must complete training on PKI operations, security procedures, and the specific tools implemented in the Goya Ledger codebase.

5.3.4 Retraining Frequency and Requirements

Retraining is required annually and upon material changes to the CPS or operational procedures.

5.3.5 Job Rotation Frequency and Sequence

Job rotation among trusted roles is implemented at the discretion of the PKI Policy Board.

5.3.6 Sanctions for Unauthorized Actions

Unauthorized actions by trusted personnel result in immediate suspension of access, investigation, and disciplinary action up to and including termination.

5.3.7 Independent Contractor Requirements

Contractors performing trusted roles must meet the same qualification and background check requirements as employees.

5.3.8 Documentation Supplied to Personnel

Trusted personnel are provided with this CPS, the CP, operational procedures, and the relevant compliance documentation in docs/compliance/.

5.4 Audit Logging Procedures

5.4.1 Types of Events Recorded

The audit subsystem (implemented in `src/audit.rs`) records the following event categories per ETSI TS 102 042:

Key Lifecycle Events: - `KeyGenerated` – new key pair creation - `KeyActivated` – key placed into operational use - `KeyDeactivated` – key removed from operational use - `KeyDestroyed` – key material securely erased - `KeyBackedUp` – key backup operation - `KeyRestored` – key restoration from backup

Certificate Lifecycle Events: - `CertificateIssued` – new certificate signed and delivered - `CertificateRenewed` – certificate re-keyed - `CertificateSuspended` – certificate placed on hold - `CertificateRevoked` – certificate permanently revoked

Revocation Service Events: - `CrlPublished` – CRL generated and published - `OcspResponseGenerated` – OCSP response signed

TSA Events: - `TimestampIssued` – RFC 3161 timestamp token generated - `TsaKeyRollover` – TSA signing key rotation

Registration Authority Events: - `IdentityProofingSubmitted` – subscriber identity proofing request received - `IdentityProofingApproved` – RA officer approved identity - `IdentityProofingRejected` – RA officer rejected identity

Security Officer Events: - `SecurityOfficerLogin` – privileged session initiated - `SecurityOfficerConfigChange` – system configuration modified - `SecurityOfficerRoleAssigned` – trusted role granted

System Events: - `SystemStartup` – node initialized - `SystemShutdown` – node stopped - `AuditLogVerified` – audit chain integrity check performed

5.4.2 Frequency of Processing Log

Audit logs are processed in real time. Each event is appended to the log immediately upon occurrence.

5.4.3 Retention Period for Audit Log

Audit logs are retained for **7 years** (`log_retention_years` in `src/pki_policy.rs`). Automated purging of records beyond the retention period is performed by the background purge task in `src/audit.rs`.

5.4.4 Protection of Audit Log

Audit log integrity is protected by a SHA-256 hash chain. Each entry contains a `previous_hash` field and an `entry_hash` computed as `SHA-256(previous_hash || canonical_data)`. The chain can be verified by `verify_audit_chain()` in `src/audit.rs`.

The audit log is append-only. Modification or deletion of entries is detectable through hash chain verification.

5.4.5 Audit Log Backup Procedures

Audit logs are included in the disaster recovery backup procedures documented in `docs/compliance/BUSINESS-CONTINUITY-DR.md`. When `STORAGE_BACKEND=rocksdb` is configured, audit logs are persisted to the RocksDB database.

5.4.6 Audit Collection System

The audit subsystem is integrated directly into the Goya Ledger application. Audit events are generated by the PKI, RA, TSA, and OCSP subsystems at the point of operation.

5.4.7 Notification to Event-Causing Subject

Audit events are transparent to the triggering entity (included in API responses where applicable). Security-sensitive events trigger alerts to the Security Officer.

5.4.8 Vulnerability Assessments

Security assessments are documented in `docs/architecture/` and include periodic review of the codebase, dependencies (`cargo audit`), and operational procedures.

5.5 Records Archival

5.5.1 Types of Records Archived

- Certificate issuance and revocation records
- RA identity proofing records (including RUT verification)
- Key ceremony records (`CeremonyRecord` in `src/pki_ceremony.rs`)
- CRL history
- Audit logs
- CPS and CP version history

5.5.2 Retention Period for Archive

All records are retained for **7 years** (configurable via `document_retention_years` in `src/pki_policy.rs`), consistent with Ley 19.799 and DS 181/2002 requirements.

5.5.3 Protection of Archive

Archives are protected by the same access controls as the operational system. Integrity of archived audit logs is verifiable through the hash chain mechanism.

5.5.4 Archive Backup Procedures

Archives are backed up per the disaster recovery plan in docs/compliance/BUSINESS-CONTINUITY-DR.md.

5.5.5 Requirements for Time-Stamping of Records

All records include timestamps. For legally significant records, RFC 3161 timestamps are available from the integrated TSA (src/tsa/mod.rs).

5.5.6 Archive Collection System

Records are collected within the Goya Ledger application and exported via CSV and JSON formats for archival.

5.5.7 Procedures to Obtain and Verify Archive Information

Archived records can be retrieved via the audit API and verified using `verify_audit_chain()`.

5.6 Key Changeover

When a CA signing key approaches the end of its operational period:

1. A new CA key pair is generated through the key ceremony process (Section 6.1.1).
2. The old CA key continues to sign CRLs and OCSP responses until all certificates it issued have expired or been revoked.
3. The new CA key is used for all new certificate issuances.
4. Both the old and new CA certificates are published for chain validation.
5. `TsaKeyRoller` events are logged for TSA key changes.

5.7 Compromise and Disaster Recovery

5.7.1 Incident and Compromise Handling Procedures

Incident response procedures are documented in docs/compliance/INCIDENT-RESPONSE-PLAN.md. Upon suspected CA key compromise:

1. Immediate suspension of certificate issuance.
2. Activation of the incident response team.
3. Assessment of the scope of compromise.
4. Revocation of affected certificates.
5. Key changeover per Section 5.6.
6. Notification to affected subscribers and relying parties.

5.7.2 Computing Resources, Software, and/or Data Are Corrupted

The disaster recovery plan in docs/compliance/BUSINESS-CONTINUITY-DR.md addresses system restoration from backups. The blockchain's Raft persistent log provides checkpoint and snapshot mechanisms.

5.7.3 Entity Private Key Compromise Procedures

See Section 4.9.12 and the incident response plan.

5.7.4 Business Continuity Capabilities After a Disaster

Business continuity capabilities are documented in docs/compliance/BUSINESS-CONTINUITY-DR.md. The multi-node architecture provides redundancy for continued PKI service availability.

5.8 CA or RA Termination

Upon planned termination of the CA or RA:

1. No new certificates are issued.
 2. All active subscribers are notified and given time to migrate.
 3. CRL and OCSP services are maintained until all issued certificates expire.
 4. All records and archives are transferred to a designated successor or retained for the full retention period.
 5. CA private keys are securely destroyed, with KeyDestroyed events logged.
-

6. Technical Security Controls

6.1 Key Pair Generation and Installation

6.1.1 Key Pair Generation

CA Key Pairs:

CA key pair generation follows the key ceremony protocol implemented in src/pki_ceremony.rs:

1. **Environment check:** The ceremony environment is validated for security.
2. **Key generation:** ECDSA P-256 key pairs are generated using rcgen with OS-backed CSPRNG (OsRng).
3. **Witness attestation:** A minimum of 2 witnesses attest to the ceremony proceedings.
4. **Key split:** The CA private key is split into shares using a 2-of-3 Shamir threshold scheme.
5. **Share distribution:** Key shares are distributed to designated custodians.
6. **Key verification:** The generated key pair is verified by signing and verifying a test message.

7. **Activation:** The key is placed into service.

Each ceremony step is recorded in a `CeremonyRecord` with SHA-256 integrity hashing. The `validate()` method enforces all required steps, minimum participants, and the notary requirement. The `finalize()` method produces a sealed, verifiable ceremony record.

Subscriber Key Pairs:

Subscriber key pairs are generated client-side using the appropriate `SigningProvider` in `src/identity/signing.rs`:

Provider	Algorithm	Public Key Size	Signature Size
<code>SoftwareSigningProvider</code>	Ed25519	32 bytes	64 bytes
<code>MlDsaSigningProvider</code>	ML-DSA-65	1,952 bytes	3,309 bytes
<code>RsaSigningProvider</code>	RSA-2048	~294 bytes (DER)	256 bytes

All providers use `OsRng` for key generation. FIPS 140-3 power-up self-tests (`run_crypto_self_tests()`) perform Known Answer Tests (KAT) for Ed25519, ML-DSA-65, RSA, and SHA-256 before any cryptographic operation. CAVP test vectors from RFC 8032 Section 7.1 are included in the test suite.

6.1.2 Private Key Delivery to Subscriber

For node certificates issued via `sign_node_cert()`, the private key is generated at the CA and returned to the node in PEM format via the `IssuedNodeCert` struct. Transport security relies on the TLS channel.

For subscriber certificates, the private key is generated and retained by the subscriber. The CA never possesses subscriber private keys.

6.1.3 Public Key Delivery to Certificate Issuer

The subscriber's public key is delivered to the CA as part of the identity proofing and certificate application process via the authenticated API.

6.1.4 CA Public Key Delivery to Relying Parties

CA public keys are distributed:

- As PEM-encoded certificates via the `TLS_CA_CERT_PATH` configuration.
- Embedded in the certificate chain of issued certificates for chain validation.
- Available for download from the CA repository.

6.1.5 Key Sizes

Key Type	Algorithm	Size / Security Level
Root CA	ECDSA P-256	256-bit

Key Type	Algorithm	Size / Security Level
Intermediate CA	ECDSA P-256	256-bit
FES Subscriber	Ed25519	256-bit (128-bit security)
FEA Subscriber	ML-DSA-65	NIST Security Level 3 (post-quantum)
Interoperability	RSA-2048	2048-bit

ML-DSA-65 (FIPS 204) provides NIST Security Level 3, offering resistance against both classical and quantum attacks.

6.1.6 Public Key Parameters Generation and Quality Checking

- Ed25519 parameters are fixed per RFC 8032.
- ML-DSA-65 parameters follow FIPS 204.
- RSA key generation uses the `rsa crate` with standard prime generation.
- Quality is verified through self-test KATs during provider initialization.

6.1.7 Key Usage Purposes

Key usage is enforced through X.509 extensions:

Certificate Profile	Key Usage Bits
FES Subscriber	<code>digitalSignature</code>
FEA Subscriber	<code>digitalSignature, nonRepudiation</code>
TSA Signing	<code>digitalSignature, timeStamping</code>
Node TLS	<code>digitalSignature, keyEncipherment</code>
CA	<code>keyCertSign, cRLSign</code>

6.2 Private Key Protection and Cryptographic Module Engineering Controls

6.2.1 Cryptographic Module Standards and Controls

The cryptographic module (`crates/pqc_crypto_module/`) is designed toward FIPS 140-3 Level 1 compliance. It provides:

- Approved mode enforcement via `approved_mode` module.
- Algorithm implementation: ML-DSA-65 (FIPS 204), SHA-256/SHA3-256 (FIPS 202).
- Self-test infrastructure in the `self_tests` module.
- Type-safe API boundaries in the `api` and `types` modules.

The module is prepared for but not yet validated under FIPS 140-3. See `docs/compliance/FIPS-140-MODULE.md` for the certification roadmap.

6.2.2 Private Key (M-of-N) Multi-Person Control

CA private keys are protected by 2-of-3 Shamir secret sharing, as configured in CeremonyConfig within `src/pki_ceremony.rs`:

- `threshold`: 2 (minimum shares required for reconstruction)
- `total_shares`: 3 (total shares distributed)
- Each share is held by a distinct custodian.
- Reconstruction requires physical presence of at least 2 custodians.

6.2.3 Private Key Escrow

CA key shares are distributed to custodians as described in Section 6.2.2. Subscriber private keys are not escrowed.

6.2.4 Private Key Backup

- **CA keys:** Backed up via HSM-to-HSM key wrapping (`CKM_AES_KEY_WRAP`) when HSM infrastructure is available. The `KeyBackedUp` audit event records all backup operations.
- **Subscriber keys:** Not backed up by the CA. Subscribers are responsible for their own key backup.

6.2.5 Private Key Archival

CA private keys are archived in accordance with the retention policy. Archived keys are protected by the same controls as operational keys.

6.2.6 Private Key Transfer Into or From a Cryptographic Module

Key transfer into or from the HSM uses PKCS#11 mechanisms. The HSM integration in `src/identity/hsm.rs` supports:

- Key lookup by `CKA_LABEL`.
- Public key extraction via `CKA_EC_POINT`.
- Ed25519 signing via `CKM_EDDSA` mechanism.
- Configuration via environment variables: `HSM_PKCS11_LIB`, `HSM_SLOT_ID`, `HSM_PIN`, `HSM_KEY_LABEL`.

6.2.7 Private Key Storage on Cryptographic Module

When the `hsm` feature is enabled, private keys reside within the HSM and are not extractable. The `HsmSigningProvider` in `src/identity/hsm.rs` implements the `SigningProvider` trait, performing all signing operations within the HSM boundary.

A `SimulatedHsmProvider` is available for testing environments.

6.2.8 Method of Activating Private Key

- **Software keys:** Activated upon loading into memory with ZeroizeOnDrop protection. Custom Drop implementations ensure zeroization for both Ed25519 and ML-DSA-65 key material.
- **HSM keys:** Activated by authenticating to the HSM with the configured PIN (HSM_PIN).

6.2.9 Method of Deactivating Private Key

- **Software keys:** Deactivated by dropping the key handle, triggering ZeroizeOnDrop. Memory is zeroed immediately upon deallocation.
- **HSM keys:** Deactivated by closing the PKCS#11 session.

The KeyDeactivated audit event is recorded upon deactivation.

6.2.10 Method of Destroying Private Key

- **Software keys:** Destroyed by secure memory zeroization via the zeroize crate.
- **HSM keys:** Destroyed via PKCS#11 C_DestroyObject.
- The KeyDestroyed audit event is recorded.

6.2.11 Cryptographic Module Rating

The cryptographic module targets FIPS 140-3 Level 1. The HSM (when deployed) shall be FIPS 140-2 Level 3 or higher certified.

6.3 Other Aspects of Key Pair Management

6.3.1 Public Key Archival

Public keys are archived as part of the issued certificate records, retained for the document retention period of 7 years.

6.3.2 Certificate Operational Periods and Key Pair Usage Periods

Certificate Type	Validity Period	Source
Root CA	10 years (2024-01-01 to 2034-01-01)	CA_NOT_BEFORE/ CA_NOT_AFTER in src/ pki.rs
Intermediate CA	5 years from generation	src/pki.rs (365 * 5 days)
FES Subscriber	365 days	src/pki_policy.rs
FEA Subscriber	365 days	src/pki_policy.rs
TSA Signing	730 days (2 years)	src/pki_policy.rs
Node TLS	365 days (default, configurable)	src/pki.rs

6.4 Activation Data

6.4.1 Activation Data Generation and Installation

- HSM PINs are generated during the key ceremony and distributed securely to authorized personnel.
- Software key activation does not require separate activation data.

6.4.2 Activation Data Protection

HSM PINs and key ceremony shares are protected by physical security controls and split knowledge procedures.

6.4.3 Other Aspects of Activation Data

Activation data for HSM access is configured via the `HSM_PIN` environment variable, which must be protected in the deployment configuration.

6.5 Computer Security Controls

6.5.1 Specific Computer Security Technical Requirements

- The node operates on the Rust nightly toolchain (specified in `rust-toolchain.toml`), benefiting from Rust's memory safety guarantees.
- All dependencies are subject to `cargo audit` vulnerability scanning.
- The access control layer (`enforce_acl`) governs API access.
- Rate limiting is enforced via `RATE_LIMIT_RPS`, `RATE_LIMIT_RPM`, and `RATE_LIMIT_RPH` configuration.
- Production deployments require TLS (`RUST_BC_ENV=production`).

6.5.2 Computer Security Rating

No formal Common Criteria evaluation has been performed. The system's security posture is documented in `docs/architecture/`.

6.6 Life Cycle Technical Controls

6.6.1 System Development Controls

- Code review required for all changes.
- Pre-commit quality gate: `cargo fmt --check`, `cargo clippy -- -D warnings`, `cargo test --lib`.
- Crypto boundary enforcement via `cargo test --test crypto_boundary`.
- Direct imports of `sha2`, `ed25519_dalek`, and other raw crypto primitives in `src/` are forbidden; all cryptographic operations must use `crates/pqc_crypto_module/`.

6.6.2 Security Management Controls

Configuration is managed through environment variables documented in `docs/api/configuration-guide.md`. Security-critical changes are logged via `SecurityOfficerConfigChange` audit events.

6.6.3 Life Cycle Security Controls

Build integrity is maintained through the Rust toolchain and Cargo dependency resolution. The `Cargo.lock` file is committed to ensure reproducible builds.

6.7 Network Security Controls

- P2P communication uses TLS via `tokio-rustls` with certificates issued by the internal CA.
- Node-to-node connections use `TlsAcceptor/TlsConnector` (implemented in `src/network/`).
- CORS is configurable via `CORS_ALLOWED_ORIGINS`.
- HTTP request timeout is configurable via `HTTP_REQUEST_TIMEOUT_SECS`.
- API endpoints are served under `/api/v1` via the `ApiRoutes::register` framework.

6.8 Time-Stamping

The Goya Ledger includes an integrated Time-Stamping Authority (TSA) conforming to RFC 3161, implemented in `src/tsa/mod.rs` and `src/tsa/rfc3161_der.rs`.

TSA Characteristics:

Parameter	Value
Policy OID	1.3.6.1.4.1.99999.1.1
Accuracy	1 second
Hash algorithms	SHA-256, SHA3-256
Signing algorithms	Ed25519, ML-DSA-65, RSA
Serial numbers	Monotonically increasing, epoch-seeded, disk-persistent
Nonce support	Echo-back for replay protection

The TSA performs signer self-validation before each token issuance. The `TimeSource` trait supports NTP-aware time retrieval, rejecting timestamps when NTP synchronization is unavailable.

TSA API Endpoints:

- `POST /api/v1/tsa/timestamp` – JSON timestamp token
- `POST /api/v1/tsa/timestamp/der` – DER-encoded RFC 3161 response (application/timestamp-reply)
- `GET /api/v1/tsa/policy` – TSA policy information

7. Certificate, CRL, and OCSP Profiles

7.1 Certificate Profile

7.1.1 Version Number

All certificates are X.509 version 3.

7.1.2 Certificate Extensions

Certificates issued by the Goya CA include the following extensions:

Standard Extensions:

Extension	OID	Critical	Content
Basic Constraints	2.5.29.19	Yes	CA:TRUE for CA certs; absent for EE certs
Key Usage	2.5.29.15	Yes	Per certificate profile (Section 6.1.7)
Subject Alternative Name	2.5.29.17	No	DNS name for node TLS certificates
Certificate Policies	2.5.29.32	No	CP OID + CPS URI qualifier

Private Extensions:

Extension	OID	Critical	Content
QCStatements	1.3.6.1.5.5.7.1.3	No	EN 319 412-5 qualified statements

7.1.3 QCStatements Extension (EN 319 412-5)

The QCStatements extension is constructed per EN 319 412-5 and embedded in subscriber certificates. It includes:

1. **QcCompliance** (OID 0.4.0.1862.1.1): Indicates the certificate is issued as a qualified certificate.
2. **QcType** (OID 0.4.0.1862.1.6): Specifies the type of certificate:

QcType	OID	Profile
id-etsi-qct-esign	0.4.0.1862.1.6.1	

QcType	OID	Profile
		Natural person (FES/FEA)
id-etsi-qct-eseal	0.4.0.1862.1.6.2	Legal person (electronic seal)
id-etsi-qct-web	0.4.0.1862.1.6.3	Website authentication (QWAC)

These OIDs are defined as constants in `src/pki_policy.rs` and the DER encoding is implemented in `build_qc_statements_der()` in `src/pki.rs`.

7.1.4 Algorithm Object Identifiers

Algorithm	OID	Usage
ECDSA with SHA-256	1.2.840.10045.4.3.2	CA signing (P-256)
Ed25519	1.3.101.112	FES subscriber signatures
ML-DSA-65	2.16.840.1.101.3.4.3.17	FEA subscriber signatures
RSA PKCS#1 v1.5 with SHA-256	1.2.840.113549.1.1.11	Interoperability
SHA-256	2.16.840.1.101.3.4.2.1	Hash algorithm
SHA3-256	2.16.840.1.101.3.4.2.8	Hash algorithm (TSA)

7.1.5 Name Forms

Issuer Distinguished Name:

CN = Goya Ledger Intermediate CA

Root CA Distinguished Name:

CN = Rust-BC Internal CA

Subscriber Distinguished Names contain at minimum: - CN = subscriber legal name (natural person) or entity name (legal person)

For node TLS certificates: - CN = node identifier - SAN `dNSName` = node identifier

7.1.6 Name Constraints

The Intermediate CA has `pathLenConstraint:0`, preventing it from issuing subordinate CA certificates.

7.1.7 Certificate Policy Object Identifier

1.3.6.1.4.1.99999.2.1 (CP OID), embedded in all certificates via the `certificatePolicies` extension with CPS URI qualifier `https://goya.cl/pki/cps`.

7.1.8 Usage of Policy Constraints Extension

Not currently used.

7.1.9 Policy Qualifiers Syntax and Semantics

The `certificatePolicies` extension includes a CPS URI qualifier pointing to `https://goya.cl/pki/cps`, constructed by `certificate_policies_extension()` in `src/pki.rs`.

7.1.10 Processing Semantics for the Critical Certificate Policies Extension

The `certificatePolicies` extension is marked non-critical, allowing relying parties that do not understand this extension to process the certificate.

7.2 CRL Profile

7.2.1 Version Number

CRLs are X.509 version 2 (v2), generated via `rcgen` in `src/msp/crl_rfc5280.rs`.

7.2.2 CRL and CRL Entry Extensions

Field	Content
Issuer	Intermediate CA DN
This Update	Current time at CRL generation
Next Update	This Update + <code>crl_validity_days</code> (default: 7 days)
CRL Number	Monotonically increasing counter
Revocation Reason	Unspecified (current implementation)
Key Identifier Method	SHA-256

7.2.3 CRL Distribution

CRLs are distributed via:

- GET `/api/v1/crl` – DER format (`application/pkix-crl`)
- GET `/api/v1/crl/pem` – PEM format (`application/x-pem-file`)

Invalid hexadecimal serial numbers in the revocation list are silently skipped during CRL generation.

7.3 OCSP Profile

7.3.1 Version Number

OCSP responses conform to RFC 6960 (OCSPv1).

7.3.2 OCSP Extensions

Extension	OID	Content
Nonce	1.3.6.1.5.5.7.48.1.2	Echo of request nonce for replay protection

7.3.3 OCSP Response Content

DER-encoded responses follow RFC 6960 Section 4.2.1 (`id-pkix-ocsp-basic`, OID 1.3.6.1.5.5.7.48.1.1), implemented in `src/msp/ocsp_der.rs`.

Field	Content
Response type	Basic OCSP Response
Responder ID	<code>byKey</code> (SHA-256 of public key, first 20 bytes)
Produced At	Current time
Cert Status	Good, Revoked, or Unknown
This Update	Current time
Next Update	This Update + <code>validity_secs</code> (default: 3600 seconds)
Signature Algorithm	Ed25519, ML-DSA-65, or RSA-SHA256

Full DER parsing and verification is available via `verify_ocsp_response_der()` in `src/msp/ocsp_der.rs`. Interoperability with `x509-parser` is verified in the test suite.

8. Compliance Audit and Other Assessments

8.1 Frequency or Circumstances of Assessment

The Goya CA undergoes compliance assessment:

- **Annual audit:** Per the Entidad Acreditadora inspection guide (Chile), as referenced in the CA obligations in `src/pki_policy.rs`.
- **Upon material CPS changes:** Any change to the CPS that affects the security or trustworthiness of the PKI triggers a review.
- **Upon security incidents:** Following any security incident affecting the CA infrastructure.

8.2 Identity/Qualifications of Assessor

Compliance assessments are performed by qualified auditors independent of CA operations. For Chilean PSC accreditation, the assessor must be recognized by the Entidad Acreditadora. The accreditation roadmap is documented in docs/compliance/PSC-CERTIFICATION-ROADMAP.md.

8.3 Assessor's Relationship to Assessed Entity

The assessor must be organizationally independent of the Goya CA operations team and free from conflicts of interest.

8.4 Topics Covered by Assessment

Assessments cover:

1. Adherence to this CPS and the governing CP.
2. Physical and logical security controls.
3. Key management practices, including ceremony records.
4. RA identity proofing procedures.
5. Audit log integrity (verification via `verify_audit_chain()`).
6. CRL and OCSP service availability and timeliness.
7. Personnel controls and separation of duties.
8. Incident response readiness.
9. Compliance with applicable legal frameworks (Ley 19.799, DS 181/2002, Decreto 24/2019, eIDAS).

8.5 Actions Taken as a Result of Deficiency

Deficiencies identified during assessment are classified by severity:

- **Critical:** Immediate remediation required; CA operations may be suspended.
- **Major:** Remediation required within 30 days.
- **Minor:** Remediation required within 90 days.

Remediation actions and their completion are recorded in the audit log.

8.6 Communication of Results

Assessment results are communicated to the PKI Policy Board and, where required, to the Entidad Acreditadora or other regulatory body. Results are retained for 7 years.

9. Other Business and Legal Matters

9.1 Fees

9.1.1 Certificate Issuance or Renewal Fees

Fee schedules for certificate issuance are determined by the Goya Ledger commercial terms. Node certificates for internal network operations are issued without charge.

9.1.2 Certificate Access Fees

Access to certificates, CRLs, and OCSP services is provided without charge to relying parties.

9.1.3 Revocation or Status Information Access Fees

Revocation and status information (CRL and OCSP) is provided without charge.

9.1.4 Fees for Other Services

Fees for other services (e.g., TSA timestamps) are determined by commercial terms.

9.1.5 Refund Policy

Refunds are governed by the applicable commercial agreement.

9.2 Financial Responsibility

9.2.1 Insurance Coverage

The Goya CA maintains appropriate insurance coverage for its PKI operations, as required by applicable law.

9.2.2 Other Assets

Not applicable.

9.2.3 Insurance or Warranty Coverage for End-Entities

Warranty coverage for end-entity certificates is defined in the subscriber agreement.

9.3 Confidentiality of Business Information

9.3.1 Scope of Confidential Information

The following information is treated as confidential:

- Subscriber private keys (never held by the CA for subscriber-generated keys).
- RA identity proofing records (including RUT and personal data).
- Audit log contents (except aggregate statistics).
- CA private key material and HSM PINs.
- Key ceremony share values.
- Security assessment reports.

9.3.2 Information Not Within the Scope of Confidential Information

The following information is public:

- This CPS and the CP.
- CA certificates and CRLs.
- OCSP responses.
- OID assignments.
- Certificate serial numbers and status.

9.3.3 Responsibility to Protect Confidential Information

All participants in the PKI are responsible for protecting confidential information in their possession per this CPS and applicable data protection law.

9.4 Privacy of Personal Information

9.4.1 Privacy Plan

Personal data collected during identity proofing is processed in accordance with Chilean Law 19.628 on the Protection of Private Life and, where applicable, the EU General Data Protection Regulation (GDPR).

9.4.2 Information Treated as Private

- Subscriber identity proofing records.
- RUT and cedula de identidad numbers.
- Biometric evidence commitments (SHA-256 hashes only; raw biometric data is never stored, per the design in src/signature/).

9.4.3 Information Not Deemed Private

- Subscriber names as they appear in issued certificates.
- DIDs (pseudonymous by design).

9.4.4 Responsibility to Protect Private Information

The CA and RA protect private information through access controls, encryption at rest (see docs/compliance/ENCRYPTION-AT-REST.md), and the audit trail.

9.4.5 Notice and Consent for Use of Personal Information

Subscribers are informed of the data processing purposes during the enrollment process and provide explicit consent.

9.4.6 Disclosure Pursuant to Judicial or Administrative Process

Personal information may be disclosed pursuant to a valid court order or administrative process under applicable law.

9.4.7 Other Information Disclosure Circumstances

No other disclosure circumstances are permitted without subscriber consent.

9.5 Intellectual Property Rights

The Goya Ledger PKI software is the intellectual property of the Goya Ledger project. The OID namespace under 1.3.6.1.4.1.99999 is a placeholder pending formal IANA PEN registration.

9.6 Representations and Warranties

9.6.1 CA Representations and Warranties

The Goya CA warrants that:

1. Certificates are issued in accordance with this CPS.
2. All information in the certificate has been verified by the RA to the extent described in this CPS.
3. CRL and OCSP services are maintained as described in this CPS.
4. Revocation requests are processed promptly.

9.6.2 RA Representations and Warranties

The RA warrants that:

1. Identity proofing is performed in accordance with Section 3.2.
2. Chilean RUT validation uses the modulo 11 algorithm as implemented.
3. Identity proofing records are retained for the required period.

9.6.3 Subscriber Representations and Warranties

Subscribers warrant that:

1. Information provided during enrollment is accurate and complete.

2. The private key is protected from unauthorized access.
3. Key compromise is reported within 24 hours.
4. The certificate is used only for permitted purposes.

9.6.4 Relying Party Representations and Warranties

Relying parties warrant that:

1. Certificate status is checked before reliance (via CRL or OCSP).
2. The certificate chain is validated to a trusted root.
3. Key usage extensions are verified for the intended use.

9.6.5 Representations and Warranties of Other Participants

Auditors, witnesses, and notaries warrant that they perform their duties honestly and in accordance with this CPS.

9.7 Disclaimers of Warranties

TO THE MAXIMUM EXTENT PERMITTED BY APPLICABLE LAW, THE GOYA CA DISCLAIMS ALL WARRANTIES NOT EXPRESSLY STATED IN THIS CPS, INCLUDING IMPLIED WARRANTIES OF MERCHANTABILITY AND FITNESS FOR A PARTICULAR PURPOSE.

9.8 Limitations of Liability

The Goya CA's liability is limited to the amounts specified in the applicable subscriber agreement, except where limitation is prohibited by law. The CA is not liable for damages arising from:

- Subscriber failure to protect private keys.
- Relying party failure to check certificate status.
- Force majeure events.
- Use of certificates for purposes not permitted under this CPS.

9.9 Indemnities

Subscribers agree to indemnify the Goya CA against claims arising from the subscriber's misuse of certificates, inaccurate enrollment information, or failure to comply with the obligations in this CPS.

9.10 Term and Termination

9.10.1 Term

This CPS is effective as of the date specified on the cover page and remains in effect until superseded or terminated.

9.10.2 Termination

This CPS may be terminated by the PKI Policy Board with 90 days' written notice. Upon termination, the CA continues to honor existing certificates until their expiration.

9.10.3 Effect of Termination and Survival

Sections on confidentiality (9.3), privacy (9.4), audit records retention (5.5), and liability (9.8) survive termination.

9.11 Individual Notices and Communications with Participants

Notices to subscribers are communicated via the API, email to the address recorded during enrollment, or through the Goya Ledger notification system.

9.12 Amendments

9.12.1 Procedure for Amendment

Amendments follow the approval procedures in Section 1.5.3. Non-material amendments (typographical corrections, formatting) may be made without the 30-day notice period.

9.12.2 Notification Mechanism and Period

Material amendments are published at least 30 days before the effective date at the CPS publication URL.

9.12.3 Circumstances Under Which OID Must Be Changed

The CPS OID is changed when amendments materially alter the trust model, supported algorithms, or assurance levels.

9.13 Dispute Resolution Provisions

Disputes arising under this CPS are resolved through:

1. Negotiation between the parties.
2. Mediation under the rules of the Centro de Arbitraje y Mediacion de Santiago (CAM Santiago).
3. Binding arbitration under Chilean law if mediation fails.

9.14 Governing Law

This CPS is governed by the laws of the Republic of Chile, in particular:

- **Ley 19.799:** Sobre Documentos Electronicos, Firma Electronica y Servicios de Certificacion de dicha Firma.
- **DS 181/2002:** Reglamento de la Ley 19.799.

- **Decreto 24/2019:** Norma Técnica para los Prestadores de Servicios de Certificación de Firma Electrónica Avanzada.

For subscribers and relying parties subject to EU jurisdiction, the eIDAS Regulation (EU 910/2014) applies as supplementary framework.

9.15 Compliance with Applicable Law

The Goya CA operates in compliance with all applicable laws and regulations, including but not limited to:

- Ley 19.799 and its implementing regulations.
- Chilean data protection law (Ley 19.628).
- ETSI TS 102 042 (CA policy requirements).
- ETSI EN 319 412 (certificate profiles).
- ETSI TS 101 733 (CAAdES).
- ETSI TS 102 778 (PAdES).
- ETSI TS 101 903 (XAdES).
- RFC 3647 (CP/CPS framework).
- RFC 5280 (X.509 PKI).
- RFC 6960 (OCSP).
- RFC 3161 (TSP).
- FIPS 186-5 (Digital Signatures).
- FIPS 204 (ML-DSA).

The full compliance framework is documented in docs/compliance/COMPLIANCE-FRAMEWORK.md.

9.16 Miscellaneous Provisions

9.16.1 Entire Agreement

This CPS, together with the governing CP, constitutes the complete statement of the CA's practices for certificate issuance and management.

9.16.2 Assignment

Rights and obligations under this CPS may not be assigned without the written consent of the PKI Policy Board.

9.16.3 Severability

If any provision of this CPS is held invalid or unenforceable, the remaining provisions continue in full force and effect.

9.16.4 Enforcement (Attorneys' Fees and Waiver of Rights)

The prevailing party in any legal proceeding arising under this CPS is entitled to reasonable attorneys' fees. No waiver of any provision constitutes a continuing waiver.

9.16.5 Force Majeure

The Goya CA is not liable for failure to perform obligations due to circumstances beyond its reasonable control, including natural disasters, war, government action, or infrastructure failure.

9.17 Other Provisions

9.17.1 Post-Quantum Cryptography Readiness

The Goya PKI is designed with post-quantum cryptographic agility. ML-DSA-65 (FIPS 204) is available as a production signing algorithm for FEA certificates, providing NIST Security Level 3 protection against quantum attacks. The PQC strategy is documented in `docs/compliance/PQC-ENTERPRISE.md` with test evidence in `docs/compliance/PQC-TEST-EVIDENCE.md`.

9.17.2 Electronic Signature Framework

The Goya PKI supports multiple advanced electronic signature formats through the `src/signature/` module:

Format	Standard	Module
CAdES	ETSI TS 101 733	<code>src/signature/cades.rs</code> , <code>src/signature/cades_der.rs</code>
PAdES	ETSI TS 102 778	<code>src/signature/pades.rs</code> , <code>src/signature/pades_der.rs</code>
XAdES	ETSI TS 101 903	<code>src/signature/xades.rs</code>

Biometric evidence for FEA signatures uses SHA-256 commitment (hash-only); raw biometric data is never stored or transmitted. Supported biometric types are defined in `src/signature/iso19794.rs`: Fingerprint, FacialRecognition, Rut, Iris, Voice, GovernmentId, and Other.

9.17.3 Decentralized Identifier Integration

Each subscriber is assigned a DID in the format `did:goya:{pubkey_hex[..16]}`, providing a stable, verifiable identifier independent of the X.509 certificate lifecycle. DID management is implemented in `src/identity/did.rs` with status tracking (Active, Revoked, Suspended) and metadata (name, email, jurisdiction).

Appendix A: Referenced Standards and Regulations

Reference	Title
RFC 3647	Internet X.509 PKI Certificate Policy and Certification Practices Framework
RFC 5280	Internet X.509 PKI Certificate and CRL Profile
RFC 6960	X.509 Internet PKI Online Certificate Status Protocol - OCSP
RFC 3161	Internet X.509 PKI Time-Stamp Protocol (TSP)
RFC 8032	Edwards-Curve Digital Signature Algorithm (EdDSA)
FIPS 186-5	Digital Signature Standard (DSS)
FIPS 204	Module-Lattice-Based Digital Signature Standard
FIPS 140-3	Security Requirements for Cryptographic Modules
ETSI TS 102 042	Policy Requirements for Certification Authorities Issuing Public Key Certificates
ETSI EN 319 412-2	Certificate Profiles – Part 2: Certificate Profile for Certificates Issued to Natural Persons
ETSI EN 319 412-3	Certificate Profiles – Part 3: Certificate Profile for Certificates Issued to Legal Persons
ETSI EN 319 412-4	Certificate Profiles – Part 4: Certificate Profile for Web Site Certificates
ETSI EN 319 412-5	Certificate Profiles – Part 5: QCStatements
ETSI TS 101 733	CMS Advanced Electronic Signatures (CAAdES)
ETSI TS 102 778	PDF Advanced Electronic Signatures (PAdES)
ETSI TS 101 903	XML Advanced Electronic Signatures (XAdES)
Ley 19.799	Sobre Documentos Electronicos, Firma Electronica y Servicios de Certificacion
DS 181/2002	Reglamento de la Ley 19.799
Decreto 24/2019	Norma Tecnica para Prestadores de Servicios de Certificacion de FEA
Ley 19.628	Sobre Proteccion de la Vida Privada
EU 910/2014	eIDAS Regulation on Electronic Identification and Trust Services

Appendix B: OID Summary

OID	Description	Defined In
1.3.6.1.4.1.99999	Goya PEN root arc	src/pki_policy.rs
1.3.6.1.4.1.99999.1.1	TSA Policy	src/pki_policy.rs, src/tsa/mod.rs
1.3.6.1.4.1.99999.2.1	Certificate Policy	src/pki_policy.rs
1.3.6.1.4.1.99999.2.2	Certification Practice Statement	src/pki_policy.rs
1.3.6.1.4.1.99999.3.1	Signature Policy	src/pki_policy.rs
0.4.0.1862.1.1	id-etsi-qcs-QcCompliance	src/pki_policy.rs
0.4.0.1862.1.6	id-etsi-qcs-QcType	src/pki_policy.rs
0.4.0.1862.1.6.1	id-etsi-qct-esign	src/pki_policy.rs
0.4.0.1862.1.6.2	id-etsi-qct-eseal	src/pki_policy.rs
0.4.0.1862.1.6.3	id-etsi-qct-web	src/pki_policy.rs

End of Certification Practice Statement